THREAT ADVISORY

Apache HTTP Server Critical HTTP/2 RCE Flaw Patched

Apache released **2.4.71 on 11 November 2026** to fix **CVE-2026-119618,** a critical race condition that can allow unauthenticated remote code execution. Versions 2.4.55 through 2.4.70 are affected when **HTTP/2** is enabled. Administrators should install the fixed release or a patched vendor package, or temporarily disable the protocol until patching is possible.

Sources: **Apache HTTP Server Security Advisory** · 11 November 2026
Red Hat RHSB-2026-017 · 12 November 2026
CVE-2026-119618 · Critical · mod_http2

Memori CTI

THREAT ADVISORY / 14 NOVEMBER 2026

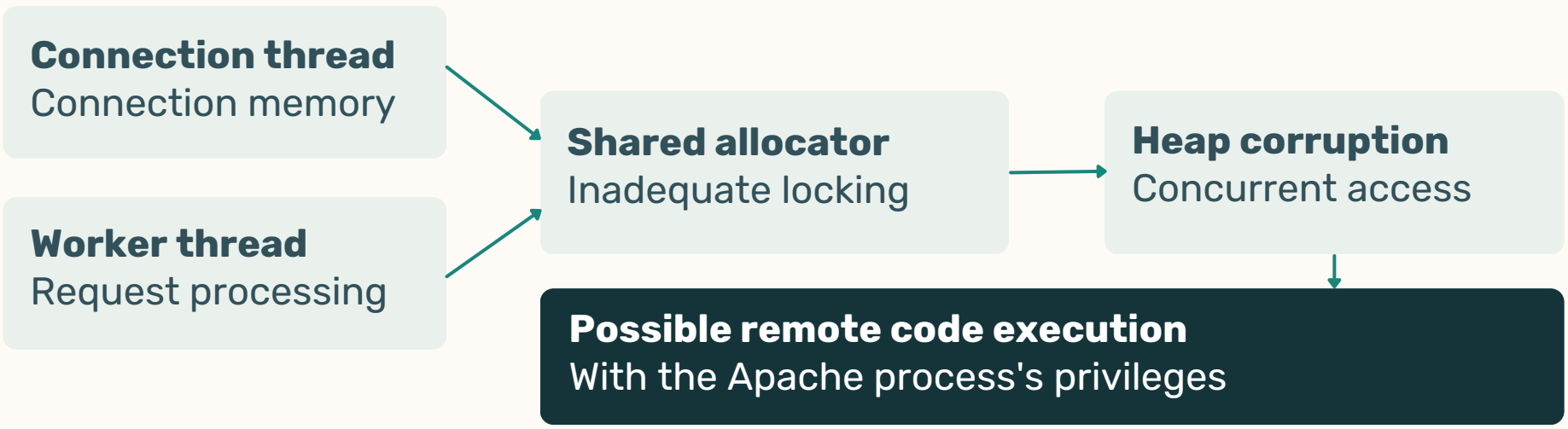
Apache patches critical HTTP/2 code execution flaw

Apache released **HTTP Server 2.4.71 on 11 November 2026**, fixing **CVE-2026-119618**, a critical vulnerability in its HTTP/2 module. An unauthenticated remote attacker can corrupt server memory and potentially execute code with the privileges of the Apache process. Exposure requires HTTP/2 to be enabled on an affected installation.

IMMEDIATE ACTION

Upgrade to Apache HTTP Server 2.4.71 or the distribution vendor's fixed package. If patching must wait, temporarily disabling HTTP/2 removes this attack path.

HOW THE RACE CONDITION AFFECTS MEMORY



The race condition in **mod_http2's assign_headers()** lets a worker modify connection-thread memory through a shared allocator without adequate locking. Concurrent access can corrupt the heap.

Root or administrator access depends on the process configuration or further exploitation.

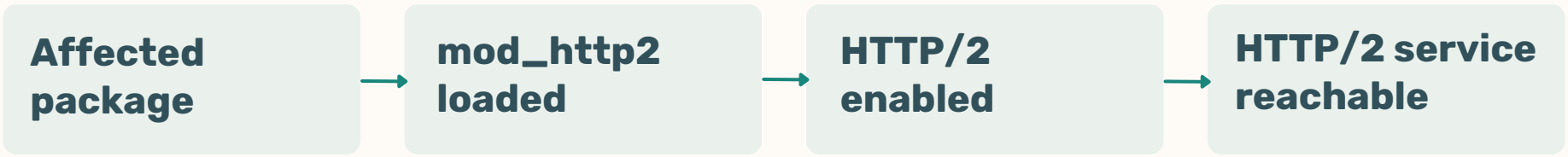
AFFECTED VERSIONS AND CONFIGURATION

Which installations are exposed?

COMPONENT	AFFECTED VERSIONS	FIXED RELEASE
Apache HTTP Server	2.4.55 through 2.4.70	2.4.71
Standalone mod_h2	2.0.8 through 2.0.42	No fixed standalone release published

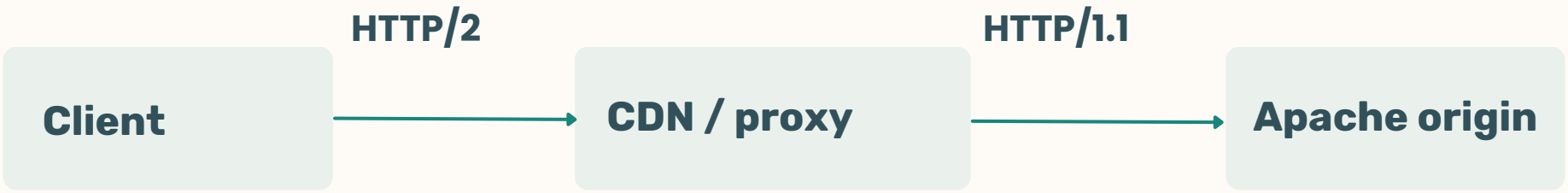
The standalone repository is archived; its latest release remains **2.0.42**. Module maintenance continues within Apache HTTP Server.

EXPOSURE REQUIRES ALL FOUR CONDITIONS



Check **Protocols** in the server-wide configuration and each virtual host: **h2** enables HTTP/2 over TLS; **h2c** enables cleartext HTTP/2. HTTP/1.1-only configurations are not exposed to this flaw.

CHECK THE PROTOCOL AT THE APACHE ORIGIN



Example: the proxy accepts HTTP/2 but forwards HTTP/1.1. Public HTTP/2 support alone does not establish origin exposure. Check direct and internal routes too.

SEVERITY AND PACKAGE DIFFERENCES

Severity and package differences

Apache classifies the vulnerability as **critical**. Red Hat assigns **CVSS v3.1 9.8**, while CISA's assessment in the CVE record assigns **8.1**. The assessments differ on attack complexity.

Risk also varies by build. RHEL 9 and RHEL 10 packages allocate memory separately for each HTTP/2 stream, making exploitation substantially harder. Their product-specific rating is **Important**, and they still require updates. RHEL 8 and earlier do not contain the affected code.

Distribution packages may include backported fixes under version numbers that differ from upstream Apache releases. Check the installed package's security status against the relevant vendor advisory.

DISCLOSURE TIMELINE

26 OCTOBER	Anthropic's OSS Scanner reports the flaw.
3 NOVEMBER	Anthony Weems and Simon Scannell of Google Cloud Vulnerability Research independently report it.
11 NOVEMBER	Apache releases HTTP Server 2.4.71 with the fix.

PUBLIC RESEARCH AND EXPLOITATION STATUS

What public research demonstrates

Red Hat states that public research demonstrated reliable exploitation against a server with mod_http2 enabled. Its advisory does not identify or link to that demonstration.

The separate **googlesky/CVE-2026-119618** repository reports reproducing memory corruption and Apache child-process crashes. Its published test does **not demonstrate remote command execution**. Those results are the researcher's reported findings; they were not independently reproduced for this report.

EVIDENCE STATUS

The reviewed material does not establish confirmed exploitation in the wild. Public crash reproduction, a working code-execution exploit and observed attacks are separate findings and should not be treated as interchangeable.

TWO OTHER FIXES IN THE RELEASE

Apache HTTP Server 2.4.71 also addresses:

CVE-2026-106023: An Important-rated NULL pointer dereference in mod_md that can crash a child process. It affects versions **2.4.30 through 2.4.70**.

CVE-2026-109163: A Low-rated one-byte stack overwrite in mod_vhost_alias, affecting versions **2.4.69 and 2.4.70**.

REMEDIATION AND TEMPORARY MITIGATION

Patching and temporary mitigation

Prioritise reachable Apache installations that accept HTTP/2. Install **2.4.71 or a vendor-supplied fixed package**, restart Apache and confirm that the updated service is running.

If an update cannot be deployed immediately, remove **h2** and **h2c** from the applicable **Protocols** directives, leaving:

```
Protocols http/1.1
```

Check virtual-host overrides before restarting the service. Review dependencies that require HTTP/2 before making the change.

> **MANAGED AND SHARED HOSTING**
>
> For managed or shared hosting, obtain confirmation that the provider has patched and restarted Apache. **Updating WordPress, plugins or themes does not fix the underlying web server.**

VERIFICATION AFTER CONFIGURATION CHANGES

Verify the Apache endpoint

Run this vendor-provided check on the Apache host, or adjust the URL to reach the Apache endpoint:

```
curl -kI --http2 https://localhost
```

ILLUSTRATIVE RESPONSES / NOT LIVE TEST OUTPUT

HTTP/2 200
HTTP/2 is still accepted.

HTTP/1.1 200 OK
HTTP/1.1 used for this check.

curl must support HTTP/2. **-k** skips certificate verification. Test Apache directly; a CDN or proxy may use a different protocol.

ALSO CHECK THE SERVER CONFIGURATION

```
grep -r 'Protocols' /etc/httpd/conf/ \
  /etc/httpd/conf.d/ 2>/dev/null
```

Paths shown are for typical Red Hat installations. Check active directives and virtual-host overrides; ignore comments.

> **WHAT THE CHECKS ESTABLISH**
>
> One HTTP/1.1 response does not establish that HTTP/2 is disabled everywhere. Check other listeners and virtual hosts. **Verify the package separately to confirm the fix.**